

INDEPENDENT SERVICE AUDITOR'S REPORT

SOC 2 Type II

NovaSoft Technologies, Inc.

Cloud-Based Data Analytics Platform

Audit Period:	January 1, 2024 – December 31, 2024
Report Date:	February 14, 2025
Prepared By:	Meridian Assurance Partners LLP
Classification:	Restricted — For Use by User Entities and Their Auditors
Trust Service Criteria:	Security, Availability, Confidentiality

This report is intended solely for the information and use of NovaSoft Technologies, Inc., user entities of NovaSoft's systems during the examination period, and their independent auditors. It is not intended to be and should not be used by anyone other than these specified parties.

Section I: Independent Service Auditor's Report

To the Management of NovaSoft Technologies, Inc.:

Scope

We have examined NovaSoft Technologies, Inc.'s ("NovaSoft" or the "Company") description of its Cloud-Based Data Analytics Platform ("the System") for processing user entities' transactions throughout the period January 1, 2024 to December 31, 2024, based on the criteria for the security, availability, and confidentiality categories set forth in the AICPA's TSP section 100, 2017 Trust Services Criteria ("applicable trust services criteria"). We also have examined the suitability of the design and operating effectiveness of controls stated in NovaSoft's description throughout the period January 1, 2024 to December 31, 2024, to meet the applicable trust services criteria.

Management's Responsibilities

NovaSoft's management is responsible for: (1) preparing the description and the assertion therein, including the completeness, accuracy, and method of presentation of the description and assertion; (2) providing the services covered by the description; (3) specifying the controls that meet the applicable trust services criteria; and (4) designing, implementing, and documenting those controls.

Service Auditor's Opinion

In our opinion, in all material respects, based on the criteria described in NovaSoft's assertion:

- a. The description fairly presents the system that was designed and implemented throughout the period January 1, 2024 to December 31, 2024.
- b. The controls stated in the description were suitably designed to provide reasonable assurance that the applicable trust services criteria would be met if the controls operated effectively throughout the period January 1, 2024 to December 31, 2024.
- c. The controls tested, which together with the complementary user entity controls and complementary subservice organization controls, if any, operated effectively throughout the period January 1, 2024 to December 31, 2024 to meet the applicable trust services criteria.

Meridian Assurance Partners LLP

San Francisco, California

February 14, 2025

Section II: Description of NovaSoft's System

2.1 Overview of NovaSoft Technologies

NovaSoft Technologies, Inc. is a cloud-native software company founded in 2018 and headquartered in San Francisco, California. The Company provides a cloud-based data analytics platform that enables enterprise customers to ingest, process, analyze, and visualize large volumes of structured and unstructured data. As of December 31, 2024, NovaSoft serves approximately 340 enterprise customers across financial services, healthcare, retail, and technology sectors.

2.2 System Components

Component	Description	Hosting
Data Ingestion API	RESTful API accepting batch and streaming data from customer systems via HTTPS. Supports JSON, CSV, Parquet, and Avro formats.	AWS us-east-1, us-west-2
Processing Engine	Distributed compute cluster for ETL operations, data transformation, and enrichment. Based on Apache Spark 3.4.	AWS (auto-scaling EC2)
Analytics Database	Columnar data warehouse storing customer datasets. Logically segregated per tenant using row-level security.	AWS RDS Aurora PostgreSQL
Visualization Layer	Web-based dashboard application serving customer-facing analytics UI. Single-page React application.	AWS CloudFront + S3
Admin Console	Internal tool for NovaSoft operations staff to manage tenant provisioning, billing, and support escalations.	AWS (internal VPC only)
Notification Service	Email and webhook delivery system for customer alerts, report delivery, and system notifications.	AWS SES + Lambda

2.3 Boundaries of the System

The system boundary includes all infrastructure, software, personnel, and procedures used to provide the NovaSoft data analytics platform. The system boundary excludes: (1) customer-owned systems and networks used to access the platform; (2) third-party identity providers integrated via SAML 2.0 or OIDC; and (3) services provided by AWS that operate outside NovaSoft's direct configuration control, including AWS physical datacenter security, which is covered by AWS's own SOC 2 report.

2.4 Subservice Organizations

NovaSoft uses the following subservice organizations, which are excluded from the scope of this report under the carve-out method. NovaSoft has obtained and reviewed SOC 2 reports for each:

Subservice Organization	Services Provided	Last Report Reviewed
-------------------------	-------------------	----------------------

Amazon Web Services	Infrastructure as a Service: compute, storage, networking, managed database services.	AWS SOC 2 Type II, Oct 2024
Twilio SendGrid	Transactional email delivery for customer notifications and system alerts.	SendGrid SOC 2 Type II, Aug 2024
PagerDuty	On-call alerting and incident management for engineering and operations teams.	PagerDuty SOC 2 Type II, Sep 2024
Okta	Workforce identity and access management for NovaSoft internal staff.	Okta SOC 2 Type II, Nov 2024

Section III: Description of Controls and Test Results

3.1 Security (CC Series) — Common Criteria

Control ID	Control Description	
CC1.1	NovaSoft has defined and communicated its commitment to security through a formal Information Security Policy, reviewed annually by the CISO and approved by the Board of Directors.	
Test performed: Inspected the Information Security Policy document. Verified Board approval signature and date (March 2024). Confirmed annual review completed.		No exceptions noted
CC2.1	NovaSoft communicates security responsibilities through onboarding training, annual security awareness training, and role-specific technical training for engineering staff.	
Test performed: Inspected training completion records for all 127 employees. Tested a sample of 25 employees. Verified onboarding completion within 30 days of hire date.		No exceptions noted
CC3.2	NovaSoft performs a formal risk assessment at least annually and when significant changes occur to the system environment. Risk assessments are documented and remediation timelines tracked.	
Test performed: Inspected 2024 risk assessment documentation dated April 2024. Verified risk register with 34 identified risks, ratings, and assigned owners. Confirmed 31 of 34 risks had documented remediation plans.		No exceptions noted
CC4.1	NovaSoft monitors the operating effectiveness of security controls through quarterly internal audits, automated compliance scanning, and exception reporting reviewed by senior management.	
Test performed: Inspected quarterly audit reports for Q1–Q4 2024. Verified automated scanning results and exception logs. Reviewed management sign-off documentation.		No exceptions noted
CC5.3	NovaSoft requires multi-factor authentication (MFA) for all access to production systems and the administrative console. Privileged access is restricted to a defined group of senior engineers.	
Test performed: Inspected MFA enforcement policy in Okta. Tested a sample of 15 user accounts; confirmed MFA enrollment. Reviewed privileged access group membership (11 users) against approved access list.		No exceptions noted
CC6.1	NovaSoft's production database enforces row-level security ensuring customers can only access their own tenant's data. Tenant isolation is implemented at the PostgreSQL policy layer and validated through automated integration tests on each deployment.	
Test performed: Inspected row-level security policy definitions in Aurora PostgreSQL. Reviewed automated test suite results for tenant isolation (488 test cases, 100% pass rate). Performed manual cross-tenant access attempt; confirmed access denied.		No exceptions noted
CC6.3	NovaSoft encrypts all customer data at rest using AES-256 via AWS KMS. Each customer tenant uses a dedicated Customer Master Key (CMK). Data in transit is encrypted using TLS 1.2 or higher.	
Test performed: Inspected AWS KMS configuration. Verified dedicated CMK per tenant for a sample of 20 customers. Tested TLS configuration using SSL Labs scan; confirmed TLS 1.2+ enforcement.		No exceptions noted
CC6.7	NovaSoft uses AWS Security Groups, Network ACLs, and a Web Application Firewall (WAF) to restrict network access to production systems. No direct internet access is permitted to database or processing tiers.	

Test performed: Inspected Security Group rules and Network ACL configurations. Verified WAF rule sets and block logs. Attempted direct access to database endpoint from external network; confirmed connection refused.		No exceptions noted
CC7.1	NovaSoft employs automated security scanning including SAST, DAST, and annual third-party penetration testing. Critical and High findings must be remediated within 30 days of identification.	
Test performed: Inspected SAST/DAST scan results and remediation tracking for 2024. Reviewed annual penetration test report (October 2024, CyberShield Security). Verified remediation SLA compliance for all findings.		Exception noted — see Section IV
CC7.2	NovaSoft has defined and implemented an incident response plan. Security incidents are logged, triaged, and escalated per defined severity levels. Post-incident reviews are conducted for Severity 1 and 2 incidents.	
Test performed: Inspected incident response plan documentation. Reviewed incident log for the audit period (47 total, 2 severity-2, 0 severity-1). Verified post-incident review documentation for both severity-2 incidents.		No exceptions noted
CC8.1	Changes to production systems follow a formal change management process including peer code review, automated testing in staging, and documented approval prior to deployment. Emergency changes require post-hoc documentation within 24 hours.	
Test performed: Inspected change management policy. Tested a sample of 30 production deployments; verified code review approval, automated test passage, and deployment authorization for each.		No exceptions noted
CC9.2	NovaSoft performs annual due diligence on vendors with access to customer data, requiring SOC 2 reports or equivalent documentation. Vendor security reviews are tracked in the vendor risk register.	
Test performed: Inspected vendor risk register. Verified SOC 2 or equivalent documentation on file for all 8 vendors with data access. Confirmed annual review completion for each.		No exceptions noted

3.2 Availability (A Series)

Control ID	Control Description	
A1.1	NovaSoft has defined availability commitments in its customer agreements, including a 99.9% monthly uptime SLA. System availability is monitored in real-time using Datadog synthetic monitoring with alerting to on-call engineers.	
Test performed: Inspected customer contract templates for SLA language. Reviewed Datadog uptime monitoring configuration and alert routing rules. Verified on-call schedule and escalation policy in PagerDuty.		No exceptions noted
A1.2	NovaSoft maintains production infrastructure across two AWS availability zones (us-east-1a and us-east-1b) with automatic failover for database and application tiers. Failover procedures are tested semi-annually.	
Test performed: Inspected AWS architecture diagrams. Reviewed auto-scaling group and RDS Multi-AZ configuration. Inspected failover test documentation for February 2024 and August 2024 exercises.		No exceptions noted
A1.3	NovaSoft performs and verifies automated database backups daily with a 30-day retention period. Backup restoration is tested quarterly. Point-in-time recovery is enabled for the production Aurora cluster.	

Test performed: Inspected AWS Backup configuration and retention policy. Reviewed backup completion logs for the audit period. Reviewed quarterly restoration test logs; confirmed successful restoration within RTO of 4 hours.		Exception noted — see Section IV
A1.4	NovaSoft maintains a Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP) reviewed annually and tested through tabletop exercises. RTO (4 hours) and RPO (1 hour) are defined and documented.	
Test performed: Inspected BCP/DRP documentation (last revised January 2024). Reviewed tabletop exercise records from June 2024 including participant list, scenarios tested, and action items. Verified RTO/RPO definitions.		No exceptions noted

3.3 Confidentiality (C Series)

Control ID	Control Description	
C1.1	NovaSoft classifies customer data as confidential by default. Data classification policies define handling requirements including storage, transmission, access, and disposal standards for confidential information.	
Test performed: Inspected data classification policy. Verified default confidential classification applied to customer data in system configuration. Reviewed data handling procedures documentation.		No exceptions noted
C1.2	NovaSoft restricts access to confidential customer data to employees with a documented business need. Access is provisioned via role-based access control (RBAC) in the Admin Console and reviewed quarterly.	
Test performed: Inspected RBAC configuration and role definitions. Reviewed Q1–Q4 2024 access review documentation. Tested a sample of 20 user accounts; confirmed access aligned with approved roles.		No exceptions noted
C1.3	Upon contract termination, customer data is deleted within 90 days and deletion is confirmed in writing to the customer. Deletion logs are maintained for audit purposes.	
Test performed: Inspected data retention policy. Reviewed deletion logs for 12 customer offboardings during the audit period. Verified written deletion confirmation letters sent and deletion completed within 90-day SLA for all 12 cases.		No exceptions noted
C1.4	NovaSoft does not share customer data with third parties except as required to provide the contracted service or as required by law. Third-party data sharing is governed by Data Processing Agreements (DPAs) with all vendors who process customer data.	
Test performed: Inspected third-party data sharing policy. Reviewed DPA agreements on file for all 8 data-processing vendors. Verified data flows documented in data flow diagrams match vendor list.		No exceptions noted

Section IV: Exceptions and Management Responses

The following exceptions were identified during the examination period. Each exception describes an instance where a control did not operate effectively, along with NovaSoft management's response and remediation plan.

Exception 1 — CC7.1: Penetration Test Finding Remediation Delay

Control Reference	CC7.1 — Security scanning and penetration testing
Exception Description	The October 2024 penetration test identified one High-severity finding: insufficient rate limiting on the authentication API endpoint, which could enable credential stuffing attacks. Per policy, High-severity findings must be remediated within 30 days of identification. As of the report date (February 14, 2025), this finding remains open at 107 days past identification, exceeding the 30-day SLA by 77 days.
Root Cause	Engineering capacity constraints during Q4 2024 product release cycle resulted in the remediation being deprioritized. The finding was tracked in the vulnerability register but escalation to senior management did not occur until January 2025.
Risk Assessment	Medium residual risk. The authentication endpoint is protected by Okta MFA for all human user sessions. API key access does not use the affected endpoint. Exploitation would require bypassing MFA, which mitigates but does not eliminate risk.
Management Response	Rate limiting has been implemented in the staging environment as of January 28, 2025 and is scheduled for production deployment February 20, 2025. A revised escalation policy requiring senior management notification within 45 days of any unresolved High finding has been drafted and is pending CISO approval.
Remediation Target	February 20, 2025 (production deployment); March 1, 2025 (revised escalation policy approval).

Exception 2 — A1.3: Backup Restoration Test Failure

Control Reference	A1.3 — Backup and restoration testing
Exception Description	During the Q3 2024 quarterly backup restoration test (August 15, 2024), the restoration of the analytics-prod-db-07 database shard failed due to a corrupted backup file. Restoration was completed using the prior day's backup, resulting in a 23-hour gap in restorable data for that shard. The backup job reported a success status despite the file corruption, so the issue was not detected during routine monitoring.
Root Cause	A bug in the backup integrity validation script caused checksum verification to be skipped for backup files exceeding 500GB. The analytics-prod-db-07 shard had grown to 612GB in Q3 2024, crossing this threshold for the first time. The bug had been present since the backup system was implemented in 2022 but had not previously manifested.
Risk Assessment	Low-to-medium residual risk. The bug has been remediated (see below). The affected shard represented approximately 4% of total customer data. Customer data was not lost; the production database remained operational throughout.

Management Response	The checksum validation bug was identified and patched on August 16, 2024. All backups have been verified successfully since the patch. The backup monitoring system was updated to alert on any backup file exceeding 80% of the 500GB threshold. A full review of backup integrity validation logic was conducted in September 2024 with no additional issues identified.
Remediation Target	Completed. Patch deployed August 16, 2024. Monitoring update deployed August 22, 2024.

Section V: Complementary User Entity Controls

NovaSoft's controls are designed with the assumption that user entities (customers) will implement certain complementary controls. The effectiveness of NovaSoft's controls to meet the applicable trust services criteria may depend on the following controls being implemented by user entities:

CUEC ID	Control Description
CUEC-1	User entities are responsible for managing their own user credentials and access to the NovaSoft platform, including promptly revoking access for terminated employees. NovaSoft's controls assume that user entity administrators maintain current user rosters and perform periodic access reviews.
CUEC-2	User entities are responsible for the accuracy and completeness of data submitted to the NovaSoft platform via the ingestion API. NovaSoft processes data as received and does not validate the accuracy of source data against user entity systems of record.
CUEC-3	User entities that integrate NovaSoft via SAML 2.0 or OIDC are responsible for the security configuration of their identity provider, including MFA enforcement policies. NovaSoft's MFA controls apply to direct-login accounts only.
CUEC-4	User entities are responsible for protecting API keys and access tokens used to authenticate to the NovaSoft ingestion API. NovaSoft assumes that user entities store API keys securely (e.g., in secrets management systems) and rotate keys at least annually.
CUEC-5	User entities are responsible for classifying the sensitivity of data submitted to the NovaSoft platform and for determining whether the platform is appropriate for processing data subject to specific regulatory requirements (e.g., HIPAA, PCI-DSS) beyond those addressed in the customer DPA.

Appendix A: Control Results Summary

Category	Total Controls	No Exceptions	Exceptions	Exception Rate
Security (CC Series)	12	11	1	8.3%
Availability (A Series)	4	3	1	25.0%
Confidentiality (C Series)	4	4	0	0.0%
TOTAL	20	18	2	10.0%

This report has been prepared by Meridian Assurance Partners LLP for the exclusive use of NovaSoft Technologies, Inc. and its customer entities. Unauthorized distribution or reproduction of this report is prohibited. Questions should be directed to NovaSoft's Chief Information Security Officer at security@novasoft-tech.com.